FastAPI Production Workshop

FastAPI in Production: Build an Order Platform, One Reliability Pattern at a Time
- Workshop control panel
  - Jump to a lab
  - Learning path
  - How to work each lab
  - Progress board
- What learners build
- 1. Core-day plan (Labs 0-8)
- 1.1 Environment contract — exactly where each lab runs
- 1.2 Code-reading contract
- 1.3 Self-learning success loop
- 2. Before the workshop
  - Install
  - Create the workspace
  - Why this layout?

Lab 0 — Bootstrap a service that can start and stop safely
- Step 0.1: configuration belongs in environment, not source code
- Step 0.2: use an app factory and lifespan
  - Failure clinic

Lab 1 — Build a predictable FastAPI boundary
- Step 1.1: make the HTTP contract explicit
- Step 1.2: return one error shape
- Step 1.3: understand async is not magic
  - Failure clinic

Lab 2 — Keep services stateless, make writes durable and idempotent
- Step 2.1: define persistence boundaries
- Step 2.2: enforce idempotency atomically
- Step 2.2b: replace the Lab 1 stub with the real write path
- Step 2.3: run local dependencies
  - Failure clinic

Lab 3 — Call other services without spreading an outage
- Step 3.0: start deterministic local dependencies
- Step 3.1: give every remote call a budget
- Step 3.2: use a bulkhead for a fragile dependency
- Step 3.3: make failures visible
  - Failure clinic

Lab 4 — Let the platform route traffic: gateway and discovery
- Step 4.1: define the gateway boundary — local Compose implementation
  - Step 4.1a: add the container image used from this point onward
  - Step 4.1b: run Kong and the service in Compose
  - Step 4.1c: configure Kong with a path that actually matches FastAPI
  - Step 4.1d: start and verify the boundary
- Step 4.2: service discovery — Compose now, Kubernetes later
  - Failure clinic

Lab 5 — Decouple the workflow with async messaging and a transactional outbox
- Step 5.1: write the event in the same transaction
- Step 5.2: accept at-least-once delivery
  - Failure clinic

Lab 6 — Coordinate distributed work with a saga
- Step 6.1: model the saga states
- Step 6.2: distinguish a compensation from rollback
  - Failure clinic

Lab 7 — Use CQRS and event sourcing for the right problem
- Step 7.1: apply CQRS before event sourcing
- Step 7.2: event sourcing is a stronger choice

Failure clinic
Lab 8 — Production platform: containers, Kubernetes, sidecars, service mesh
Step 8.0: create the optional local Kubernetes platform
Step 8.1: promote the same image built in Lab 4
Step 8.2: deploy statelessly
Step 8.3: understand the sidecar pattern
Step 8.4: translate the local gateway path to an Istio ingress gateway
Step 8.5: make mesh traffic policy explicit
Failure clinic
Capstone — Run a controlled failure game day
Completion rubric
Instructor notes and extension path
Suggested checkpoints
Production additions deliberately left as follow-on labs
A pragmatic decision guide
Advanced Production Extension — From Reliable Services to Operable Systems
Advanced-day plan (Labs 9-14)
Lab 9 — Admit only the work the system can safely handle
Step 9.1: separate three controls
Step 9.2: apply a distributed rate limit at the gateway
Step 9.3: bound expensive in-process work
Step 9.4: turn non-interactive work into a queue
Failure clinic
Lab 10 — Make event-driven systems recoverable and evolvable
Step 10.1: use an explicit event envelope
Step 10.2: classify failures before retrying
Step 10.3: evolve additively first
Step 10.4: test the contract in CI
Failure clinic
Lab 11 — Observe request paths, not isolated services
Step 11.1: carry a trace across every hop
Step 11.2: use structured logs and meaningful metrics
Step 11.3: define service-level objectives
Failure clinic
Lab 12 — Apply zero-trust identity and authorization
Step 12.1: separate human, workload, and permission identity
Step 12.2: enforce permissions in the application
Step 12.3: restrict network paths with mesh policy
Failure clinic
Lab 13 — Release safely when services and schemas evolve independently
Step 13.1: use expand-migrate-contract for database changes
Step 13.2: use a feature flag for behavior changes
Step 13.3: canary traffic before full rollout
Step 13.4: drain before termination
Failure clinic
Lab 14 — Scale data deliberately: caches, ownership, partitions, recovery
Step 14.1: use cache-aside only for safely stale reads
Step 14.2: prevent cache stampedes
Step 14.3: make ownership explicit
Step 14.4: choose partitions and regional recovery intentionally
Failure clinic
Advanced capstone — Operate the platform through a release and traffic incident
Extended completion rubric
Interactive incident drills
Drill 1 — “The user says they were charged twice”
Drill 2 — “Kafka lag rises but API success is 99.99%”
Drill 3 — “A canary looks healthy, but customers cannot complete checkout”
Drill 4 — “A support token accesses another tenant’s order”
Drill 5 — Choose the next pattern
Self-learning runbook and review checklist
Start and stop safely
Core local environment: Labs 0-7
Compose gateway environment: Labs 4-7 and 9-11
Kubernetes platform environment: Lab 8 and platform parts of Labs 12-13
Completion evidence by lab

Common ambiguity breakers
Deliberately simplified versus production-required

FastAPI in Production: Build an Order Platform, One Reliability Pattern at a Time

Format: core day (Labs 0-8, 7.5 hours) + optional advanced day (Labs 9-14, 6.5 hours)
Audience: AI engineers comfortable with Python and familiar with basic FastAPI routing
Runtime: Docker Compose locally; Kubernetes + Istio concepts and manifests for production

Tip

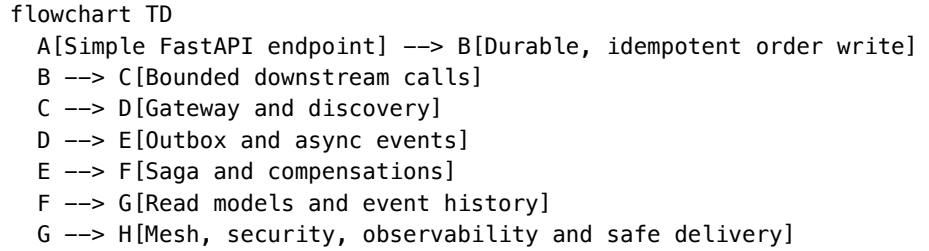
Use this as a workbook, not a document to read end-to-end. For every lab: run the happy path, inject the stated failure, observe it through logs/metrics, apply the pattern, and prove the recovery.

Workshop control panel

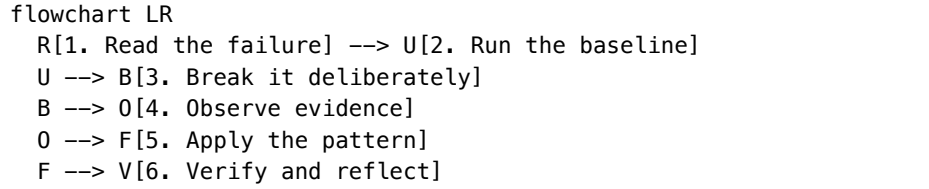
Jump to a lab

Foundation	Reliability	Distributed workflow	Platform and operations
Lab 0: bootstrap	Lab 3: dependency failure	Lab 5: async messaging	Lab 8: Kubernetes and mesh
Lab 1: FastAPI boundary	Lab 4: gateway and discovery	Lab 6: saga	Lab 9: admission control
Lab 2: stateless writes	Lab 10: messaging operations	Lab 7: CQRS and event sourcing	Labs 11-14: operate at scale

Learning path



How to work each lab



Step	Learner action	Evidence to capture
Run	Execute the provided command or endpoint.	Response, record count, message offset, or trace ID.

Step	Learner action	Evidence to capture
Break	Introduce the controlled failure exactly once.	Timeout, duplicate command, restart, invalid event, or failed deployment.
Observe	Inspect logs, metrics, queue age, or database state.	What actually happened—not what you expected.
Fix	Apply the smallest pattern that contains the failure.	Code/configuration diff.
Verify	Repeat the same failure.	Expected safe behavior and no duplicate side effects.

Important

Do not mark a lab complete because the code starts. Mark it complete only after you can explain the failure mode, demonstrate it, and show why the pattern changes the outcome.

Progress board

Copy this checklist into your own notes and check items as you complete the evidence, not merely the reading.

- ▢ Lab 0 - service starts, stops, and exposes correctly scoped health checks
- ▢ Lab 1 - invalid input and blocking I/O have been demonstrated
- ▢ Lab 2 - concurrent duplicate order requests persist one order
- ▢ Lab 3 - timeout, bulkhead, and circuit-breaker recovery have been observed
- ▢ Lab 4 - traffic reaches the service through gateway/discovery rather than a Pod address
- ▢ Lab 5 - outbox recovers an event after a simulated crash; consumer ignores a duplicate
- ▢ Lab 6 - a compensation runs after a downstream saga step fails
- ▢ Lab 7 - query projection lag and aggregate version conflict have been explained
- ▢ Lab 8 - a Pod rollout, readiness, and mesh policy have been inspected
- ▢ Labs 9-14 - traffic pressure, DLQ, trace, authorization, canary, and cache failure scenarios have been completed

▶ **Before starting: how do I know which pattern to use?**

What learners build

By the end, learners have evolved a single `order-service` into a small but realistic order platform.

```
flowchart LR
  C[Web / AI client] --> G[API Gateway]
  G --> O[Order service]
  O --> P[PostgreSQL]
  O <--> I[Inventory service]
  O <--> PY[Payment service]
  O --> K[(Kafka / Redpanda)]
  K --> S[Shipping service]
  K --> N[Notification service]
  O -. telemetry .-> T[OpenTelemetry collector]
```

The business flow is intentionally familiar: **place an order**. A customer buys items; inventory must be reserved, payment authorized, shipment created, and a confirmation sent. Those operations live in different services and can fail independently. Each lab adds one production capability because the earlier, simpler version has a concrete failure.

> Scope note: FastAPI is an HTTP application framework. API gateway, service discovery, and a service mesh are platform responsibilities. A production backend needs to cooperate with them cleanly instead of reimplementing them in Python.

1. Core-day plan (Labs 0-8)

Time	Lab	The pain we expose	What learners add
09:30–10:00	0. Bootstrap	"It works on my laptop"	repeatable local stack, health checks, environment-based settings
10:00–10:50	1. Production-ready FastAPI core	invalid requests, blocking handlers, opaque errors	app factory, lifespan, validation, async I/O, error contract
11:00–11:45	2. Stateless order API	duplicate requests and lost state on restart	PostgreSQL, idempotency, transactions, migrations
11:45–12:30	3. Synchronous dependencies	payment or inventory makes checkout hang	timeouts, retries, circuit breaker, bulkhead
13:15–14:05	4. Gateway and discovery	clients know too much about services	API gateway, service discovery, zero-trust boundaries
14:05–15:05	5. Async messaging	response path is too long; events get lost	transactional outbox, Kafka/Redpanda, idempotent consumer
15:15–16:00	6. Distributed consistency	payment succeeds but stock/shipping fails	saga orchestration and compensations
16:00–16:40	7. CQRS + event sourcing	order history/query needs diverge	projections, event store, replay
16:40–17:20	8. Kubernetes, sidecar, mesh	per-service networking/telemetry policy drift	Deployment, HPA, Istio sidecar, traffic policy
17:20–17:30	Capstone	prove reliability	failure game day and review

1.1 Environment contract — exactly where each lab runs

This course deliberately uses **two environments**, in sequence. Do not attempt to introduce Kubernetes or a service mesh while learning the basic request/data patterns. It makes failures harder to attribute.

Course phase	Labs	Runtime learners use	Discovery and routing mechanism	What is intentionally out of scope
Local foundation	0-7, 9-11, 13-14	Docker Compose plus local Python tools	Compose DNS: `http://order-service:8000`; Kong at `http://localhost:8000`	Kubernetes, Istio, cloud load balancers
Platform translation	8 and the Kubernetes parts of 12-13	`kind` or `minikube` plus Istio	Kubernetes `Service` + CoreDNS; ingress/gateway; Envoy sidecar	Recreating every local lab inside a cluster

```
flowchart LR
  subgraph Local["Labs 0–7: Docker Compose on your laptop"]
    LClient[Client] --> LKong[Kong :8000]
    LKong --> LOrder[order-service]
    LOrder --> LInventory[inventory-service]
    LOrder --> LPayment[payment-service]
    LOrder --> LDB[(Postgres)]
```

```
  end
  Local -. "Lab 8: translate the same boundary" .-> Cluster
  subgraph Cluster["Labs 8+: Kubernetes + Istio"]
    KClient[Client] --> KIngress[Ingress / Gateway]
    KIngress --> KSvc[Kubernetes Service]
    KSvc --> KPod[Order Pod + Envoy sidecar]
    KPod --> KMesh[Internal services via mesh]
  end
```

Note

Lab 4 is a Docker Compose lab. It runs Kong locally and uses Compose DNS for service discovery. Lab 8 later maps that same idea to Kubernetes `Service`, CoreDNS, readiness endpoints, ingress, and Istio. A Kubernetes manifest shown before Lab 8 is explanatory only; do not apply it yet.

1.2 Code-reading contract

The guide uses three snippet kinds. This prevents a learner from assuming every short example is a complete production repository.

Label	Meaning	What you should do
RUN	Complete enough to execute after the stated setup.	Copy it into the named file and run the verification command.
WIRE	Shows how two pieces connect; surrounding repository code is referenced.	Add it after the earlier lab files exist.
CONCEPT	Explains a production design choice or a platform policy.	Read it, then use the exercise to validate the behavior.

Unless explicitly marked **CONCEPT**, code is written to be copied as a starting point. Production systems still need tests, secret injection, pinned image versions, security review, and organization-specific platform configuration.

1.3 Self-learning success loop

At every lab, keep this evidence in a `notes.md` file: command run, expected output, observed failure, applied change, and retest output. This turns the course into an auditable engineering exercise rather than passive reading.

```
notes/
  lab-02-idempotency.md     # duplicate request evidence and database
query result
  lab-03-resilience.md      # timeout/breaker metrics and recovery
observation
  lab-05-outbox.md          # crash simulation and eventual event
delivery
  lab-08-platform.md        # rollout/readiness/mesh evidence
```

2. Before the workshop

Install

- Python 3.12+ and `uv` (or pip + virtualenv)
- Docker Desktop with Compose
- `kubectl`; optionally `kind` or `minikube`
- A local Kubernetes cluster and Istio only for Lab 8

Create the workspace

```
mkdir -p fastapi-production-workshop/{services,infra,k8s}
cd fastapi-production-workshop
uv init
uv add fastapi 'uvicorn[standard]' sqlalchemy asyncpg alembic \
  httpx tenacity aiobreaker structlog prometheus-fastapi-
        instrumentator \
  opentelemetry-api opentelemetry-sdk opentelemetry-exporter-otlp \
  opentelemetry-instrumentation-fastapi opentelemetry-instrumentation-
        httpx \
  aiokafka
uv add --dev pytest pytest-asyncio respx ruff
```

All application code lives under `services/order_service/app/`. Every file path in this workshop is relative to the repository root and uses this prefix. Do not create a second `app/` package at the repository root. The app factory is `services/order_service/app/main.py`, and the server runs as `services.order_service.app.main:app`.

Create the directories first, then the package marker files, so imports work the same from a terminal, a test runner, and a container. `touch` does not create missing parent folders, so `mkdir -p` must run before it:

```
mkdir -p
        services/order_service/app/{api,application,domain,infrastructure}
        \
  services/mock_dependency infra/gateway tests/contracts notes
touch services/__init__.py services/order_service/__init__.py \
  services/order_service/app/__init__.py \
  services/order_service/app/{api,application,domain,infrastructure}/__init__.py \
  services/mock_dependency/__init__.py
```

Create `.env.example`. Labs 0-3 run FastAPI on the host, so Kafka uses `localhost`; the host process cannot resolve the Compose name `redpanda`. Lab 4 uses `infra/.env.compose` for container hostnames.

```
DATABASE_URL=postgresql+asyncpg://orders:orders@localhost:5432/orders
INVENTORY_URL=http://localhost:8002
PAYMENT_URL=http://localhost:8003
KAFKA_BOOTSTRAP_SERVERS=localhost:9092
```

Ignore it, then copy it:

```
echo ".env" >> .gitignore
cp .env.example .env
```

Warning

`.env` is for local learning only and is ignored by Git. Production credentials belong in a secret manager and are injected at runtime; never commit passwords or tokens.

Suggested layout after Lab 5:

```
.env.example
.env                            # copied from .env.example; git-ignored
pyproject.toml
services/
  order_service/
    Dockerfile
    alembic/
    app/
      main.py                   # create_app() and module-level app
      config.py
      observability.py          # Lab 8
```

```
      api/                    # routes and error handlers
      application/            # use cases
      domain/
      infrastructure/         # Postgres, HTTP, Kafka adapters
  mock_dependency/
  inventory_service/
  payment_service/
  shipping_service/
infra/
  compose.yaml
  .env.compose
  sql/
  gateway/                    # Kong/Envoy config
k8s/
  base/                       # manifests
  istio/                      # DestinationRule, VirtualService
tests/
  contracts/
notes/
```

Why this layout?

Routes only translate HTTP into an application command. Domain rules do not import FastAPI, SQLAlchemy, or Kafka. Infrastructure adapts a port to Postgres/HTTP/Kafka. This keeps business logic testable and lets infrastructure change without a rewrite.

Lab 0 — Bootstrap a service that can start and stop safely

Goal: establish the non-negotiable baseline used by all later labs.

Step 0.1: configuration belongs in environment, not source code

Create `services/order_service/app/config.py`:

```python
import os
from functools import lru_cache


class Settings:
    def __init__(self):
        self.app_name = os.getenv("APP_NAME", "order-service")
        self.environment = os.getenv("ENVIRONMENT", "local")
        self.database_url = os.environ["DATABASE_URL"]
        self.inventory_url = os.getenv("INVENTORY_URL",
        "http://inventory-service:8000")
        self.payment_url = os.getenv("PAYMENT_URL", "http://payment-
        service:8000")
        self.kafka_bootstrap_servers =
        os.getenv("KAFKA_BOOTSTRAP_SERVERS", "redpanda:9092")

@lru_cache
def get_settings():
    return Settings()
```

Try it: while FastAPI runs on your laptop in Labs 0-3, set `DATABASE_URL=postgresql+asyncpg://orders:orders@localhost:5432/orders`. Start without it once. The service should fail at startup rather than serving traffic with a broken configuration. In Lab 4, the app moves into Compose and the hostname changes to `postgres`; the two environment files make that explicit.

Step 0.2: use an app factory and lifespan

```python
# services/order_service/app/main.py
from contextlib import asynccontextmanager
from fastapi import FastAPI
from .config import get_settings


@asynccontextmanager
async def lifespan(app):
    settings = get_settings()
    # Create expensive shared clients/pools here. Do not create one
        per request.
    app.state.settings = settings
    yield
    # Close pools/producers here after Kubernetes removes this Pod
        from endpoints.


def create_app():
    app = FastAPI(title="Order Service", version="0.1.0",
        lifespan=lifespan)

    @app.get("/livez", include_in_schema=False)
    async def livez():
        return {"status": "alive"}

    @app.get("/readyz", include_in_schema=False)
    async def readyz():
        # Lab 2 checks DB; Lab 5 checks whether messaging can publish.
        return {"status": "ready"}
    return app


app = create_app()
```

Run it:

```
uv run uvicorn services.order_service.app.main:app --env-file .env --
        reload --port 8000
curl localhost:8000/livez
```

Failure clinic

Symptom	Why it happens	Fix
`RuntimeWarning: coroutine was never awaited`	an async startup/cleanup function was called like normal Python	call it with `await` inside lifespan
a new database/HTTP client appears in every request	connection setup was placed inside a route/dependency without caching	create one pool/client in lifespan and close it on shutdown
`asyncio.run() cannot be called from a running event loop`	the ASGI server already owns the loop	make the function `async` and `await` it

Symptom	Why it happens	Fix
readiness succeeds while DB is unavailable	`/readyz` only checks process liveness	make readiness a lightweight dependency check; keep `/livez` process-only

Checkpoint: explain why a liveness probe must not query Postgres. If Postgres is down, restarting every otherwise healthy Pod amplifies the outage.

Lab 1 — Build a predictable FastAPI boundary

Problem: a demo endpoint accepts anything, returns inconsistent exceptions, and blocks the event loop under load.

Step 1.1: make the HTTP contract explicit

Request bodies are declared as Pydantic models. FastAPI validates every field before the handler runs, generates OpenAPI documentation from the same models, and passes the handler typed objects instead of raw dictionaries.

```python
# services/order_service/app/api/orders.py
from uuid import UUID
from decimal import Decimal
from fastapi import APIRouter, Header, status
from pydantic import BaseModel, Field

router = APIRouter(prefix="/v1/orders", tags=["orders"])

class OrderLine(BaseModel):
    sku: str = Field(min_length=1)
    quantity: int = Field(gt=0)
    unit_price: Decimal = Field(gt=0)

class CreateOrderRequest(BaseModel):
    customer_id: UUID
    lines: list[OrderLine] = Field(min_length=1)

@router.post("", status_code=status.HTTP_202_ACCEPTED)
async def create_order(
    body: CreateOrderRequest,
    idempotency_key: str = Header(min_length=16, max_length=128),
):
    # The application service is introduced in Lab 2.
    return {"order_id": "created-in-lab-2", "status": "PENDING"}
```

Key decisions:

- Request and response data are separate. Never serialize ORM objects directly.
- Money is `Decimal`, never `float`.
- An order may complete asynchronously, so return `202 Accepted` with a stable order ID.
- Idempotency is a protocol feature, not a UI feature. Mobile retries, gateways, and clients can all repeat a POST.

Step 1.2: return one error shape

```
# services/order_service/app/api/errors.py
from uuid import uuid4

from fastapi import FastAPI
from fastapi.exceptions import RequestValidationError
from fastapi.responses import JSONResponse


class DomainError(Exception):
    def __init__(self, code, message, status_code=409):
        self.code, self.message, self.status_code = code, message,
        status_code


def install_error_handlers(app: FastAPI):
    @app.exception_handler(DomainError)
    async def domain_error(_, exc):
        trace_id = str(uuid4())  # In Lab 8 obtain current OTEL trace
        ID instead.
        return JSONResponse(
            status_code=exc.status_code,
            content={"code": exc.code, "message": exc.message,
        "trace_id": trace_id},
        )

    @app.exception_handler(RequestValidationError)
    async def validation_error(_, exc):
        trace_id = str(uuid4())  # In Lab 8 obtain current OTEL trace
        ID instead.
        return JSONResponse(
            status_code=422,
            content={
                "code": "VALIDATION_ERROR",
                "message": "Request validation failed",
                "trace_id": trace_id,
                "details": [
                    {"field": ".".join(map(str, e["loc"])), "message":
        e["msg"]}
                    for e in exc.errors()
                ],
            },
        )
```

Register the router and handlers in `create_app()`. Then send invalid data:

```
# services/order_service/app/main.py — add these imports
from .api.errors import install_error_handlers
from .api.orders import router as orders_router

# services/order_service/app/main.py — add these two lines inside
        create_app(), before return app
install_error_handlers(app)
app.include_router(orders_router)

curl -i -X POST localhost:8000/v1/orders \
  -H 'content-type: application/json' -H 'Idempotency-Key: a-very-
        long-client-generated-key' \
  -d '{"customer_id":"not-a-uuid","lines":[]}'
```

FastAPI's 422 validation response is useful, but standardize it too if your API has an external contract.

Step 1.3: understand async is not magic

```python
# Wrong: blocks every request sharing this event loop worker.
@router.get("/wrong")
async def wrong():
    import time
    time.sleep(2)
    return {"ok": True}

# Right for network I/O: the HTTP client yields while waiting.
import httpx
@router.get("/right")
async def right():
    async with httpx.AsyncClient(timeout=1.0) as client:
        response = await client.get("https://example.internal/health")
    return response.json()
```

For CPU-heavy tokenization, document parsing, or local model inference, use a worker system (Celery/Arq/Temporal/Kubernetes Job) or a process pool. `async def` does not make CPU work parallel.

Failure clinic

Symptom	Root cause	Fix
p99 latency jumps whenever one request calls `time.sleep`, `requests`, or a blocking SDK	the event loop is blocked	use an async library; otherwise run blocking work in a bounded threadpool or external worker
`422` has fields clients cannot rely on	default validator detail leaked as the API contract	add a validation exception handler and publish your `Problem` shape
duplicate / missing headers in an AI agent client	headers were not enforced by contract	explicitly model `Header(...)`; reject absent idempotency keys for unsafe operations
`float` price is `19.989999...`	binary floating-point	accept/compute money as `Decimal`, serialize a documented string/decimal form

Lab 2 — Keep services stateless, make writes durable and idempotent

Problem: an in-memory `dict` loses orders after a restart and concurrent retries create two orders.

Step 2.1: define persistence boundaries

```python
# services/order_service/app/infrastructure/db.py
from sqlalchemy.ext.asyncio import async_sessionmaker,
        create_async_engine
from ..config import get_settings

engine = create_async_engine(
    get_settings().database_url,
    pool_pre_ping=True, pool_size=10, max_overflow=20,
)
SessionFactory = async_sessionmaker(engine, expire_on_commit=False)
```

```
async def get_session():
    async with SessionFactory() as session:
        yield session
```

For the first local run, save this as `infra/sql/001_orders.sql`. The course executes it directly so you can focus on the behavior. In a production repository, commit the same change as an Alembic migration; Lab 13 covers the safe evolution rule.

```
CREATE TABLE orders (
  id UUID PRIMARY KEY,
  customer_id UUID NOT NULL,
  status TEXT NOT NULL,
  total NUMERIC(10,2) NOT NULL,
  created_at TIMESTAMPTZ NOT NULL DEFAULT now()
);
CREATE TABLE idempotency_keys (
  key TEXT PRIMARY KEY,
  request_hash TEXT NOT NULL,
  order_id UUID NOT NULL REFERENCES orders(id),
  created_at TIMESTAMPTZ NOT NULL DEFAULT now()
);
```

Step 2.2: enforce idempotency atomically

```
# services/order_service/app/application/create_order.py
from hashlib import sha256
from json import dumps
from uuid import uuid4
from decimal import Decimal
from sqlalchemy import text
from ..api.errors import DomainError

async def create_order(session, command, idempotency_key):
    # `command` is `CreateOrderRequest.model_dump(mode="json")` from
        the Lab 1 route.
    payload = command
    request_hash = sha256(dumps(payload,
        sort_keys=True).encode()).hexdigest()
    order_id = uuid4()

    async with session.begin():
        result = await session.execute(text("""
          INSERT INTO idempotency_keys(key, request_hash, order_id)
          VALUES (:key, :hash, :order_id)
          ON CONFLICT (key) DO NOTHING
          RETURNING order_id
        """), {"key": idempotency_key, "hash": request_hash,
        "order_id": order_id})
        inserted = result.scalar_one_or_none()

        if inserted is None:
            existing = await session.execute(text(
              "SELECT request_hash, order_id FROM idempotency_keys
        WHERE key = :key"),
              {"key": idempotency_key})
            old_hash, old_order_id = existing.one()
            if old_hash != request_hash:
                raise DomainError("IDEMPOTENCY_KEY_REUSED", "Key
        belongs to another request", 422)
            return old_order_id, True
```

```
        total = sum(
            Decimal(str(line["unit_price"])) * int(line["quantity"])
            for line in command["lines"]
        )
        await session.execute(text("""
          INSERT INTO orders(id, customer_id, status, total)
          VALUES (:id, :customer_id, 'PENDING', :total)
        """), {"id": order_id, "customer_id": command["customer_id"],
         "total": total})
    return order_id, False
```

The unique key is the concurrency control. Checking first with `SELECT` is race-prone: two requests can both observe "missing."

Step 2.2b: replace the Lab 1 stub with the real write path

In `services/order_service/app/api/orders.py`, replace the temporary Lab 1 endpoint with this version. This is the missing wiring between HTTP, the database session, and the application function above.

```
from fastapi import APIRouter, Depends, Header, status
from ..infrastructure.db import get_session
from ..application.create_order import create_order as persist_order

# CreateOrderRequest and OrderLine are unchanged from Step 1.1.
router = APIRouter(prefix="/v1/orders", tags=["orders"])

@router.post("", status_code=status.HTTP_202_ACCEPTED)
async def create_order_endpoint(
    body: CreateOrderRequest,
    idempotency_key: str = Header(min_length=16, max_length=128),
    session = Depends(get_session),
):
    order_id, replayed = await persist_order(
        session, body.model_dump(mode="json"), idempotency_key
    )
    return {
        "order_id": str(order_id),
        "status": "PENDING",
        "idempotent_replay": replayed,
    }
```

Now run the same request twice. The first response has `idempotent_replay: false`; the second has `true` and the same `order_id`.

Step 2.3: run local dependencies

```
# infra/compose.yaml
services:
  postgres:
    image: postgres:16-alpine
    environment:
      POSTGRES_USER: orders
      POSTGRES_PASSWORD: orders
      POSTGRES_DB: orders
    ports: ["5432:5432"]
    healthcheck:
      test: ["CMD-SHELL", "pg_isready -U orders -d orders"]
      interval: 5s
```

```
      timeout: 3s
      retries: 10
  redpanda:
    image: redpandadata/redpanda:latest
    command: redpanda start --overprovisioned --smp 1 --memory 1G --
        node-id 0 --check=false
    ports: ["9092:9092", "9644:9644"]
```

```
# Labs 0–3 run FastAPI on the host; only dependencies run in Compose.
docker compose -f infra/compose.yaml up -d postgres redpanda
docker compose -f infra/compose.yaml exec -T postgres \
  psql -U orders -d orders < infra/sql/001_orders.sql

# Confirm that the tables exist before starting the API.
docker compose -f infra/compose.yaml exec -T postgres \
  psql -U orders -d orders -c '\dt'
```

Expected result: `orders` and `idempotency_keys` appear in the table list. If the database is reset, rerun the same schema file. Do not make the application run DDL on startup; in a production service the deployment pipeline executes a reviewed migration before enabling new code.

Failure clinic

Symptom	Why	Fix
two orders for the same request under load	"read then insert" has a race	unique constraint + `INSERT ... ON CONFLICT` in one transaction
the same key with a changed cart silently returns the old order	key is treated only as a cache	store and compare a canonical request hash; return 422 on mismatch
`MissingGreenlet` from SQLAlchemy	ORM lazy-load triggered I/O outside `await`	load relations explicitly, use async APIs, or return DTOs before leaving the session
`too many connections` during a traffic spike	each worker has an unbounded/default pool	calculate pools across all replicas; cap `pool_size`/`max_overflow`; use PgBouncer when appropriate
Pods contain orders in memory	state was kept in globals/session	persist durable state; use Redis only for disposable cache/rate limits, not source of truth

Production rule: a stateless service may cache locally, but the correct response must not depend on which replica receives the request.

Lab 3 — Call other services without spreading an outage

Problem: checkout calls inventory and payment synchronously. When payment slows, each request holds resources waiting; retries multiply load and all order workers become unavailable.

Step 3.0: start deterministic local dependencies

Labs 0-3 run FastAPI on the host, so use two intentionally small mock services on your laptop. They make timeout and failure behavior repeatable without a real payment provider.

Create `services/mock_dependency/main.py`:

```
import asyncio
import os
from uuid import uuid4
from fastapi import FastAPI, HTTPException

app = FastAPI()

@app.get("/health")
async def health():
    return {"dependency": os.getenv("DEPENDENCY_NAME", "mock"),
        "status": "ok"}

@app.post("/authorizations")
async def authorize():
    delay = float(os.getenv("DELAY_SECONDS", "0"))
    if delay:
        await asyncio.sleep(delay)
    if os.getenv("FAIL_MODE") == "500":
        raise HTTPException(500, "Simulated payment outage")
    if os.getenv("FAIL_MODE") == "decline":
        raise HTTPException(402, "Simulated card decline")
    return {"authorization_id": str(uuid4())}

@app.post("/reservations")
async def reserve():
    return {"reservation_id": str(uuid4())}
```

Start the mocks in separate terminals:

```
# Terminal 1: inventory mock
DEPENDENCY_NAME=inventory uv run uvicorn
        services.mock_dependency.main:app --port 8002

# Terminal 2: payment mock
DEPENDENCY_NAME=payment uv run uvicorn
        services.mock_dependency.main:app --port 8003

# Terminal 3: verify both before running the order service
curl http://localhost:8002/health
curl http://localhost:8003/health
```

Expected result: each health endpoint returns its dependency name and `status: ok`. Lab 4 runs the exact same mock module as Compose services, so the only thing that changes is the hostname.

Step 3.1: give every remote call a budget

```
# services/order_service/app/infrastructure/payment_client.py
import httpx
from datetime import timedelta
from aiobreaker import CircuitBreaker

class PaymentDeclined(Exception):
    pass

class PaymentUnavailable(Exception):
    pass

payment_breaker = CircuitBreaker(
    fail_max=5,
```

```
    timeout_duration=timedelta(seconds=30),
    exclude=[PaymentDeclined],
)

class PaymentClient:
    def __init__(self, base_url, client):
        self.base_url, self.client = base_url, client

    @payment_breaker
    async def authorize(self, order_id, amount):
        try:
            response = await self.client.post(
                f"{self.base_url}/authorizations",
                json={"order_id": order_id, "amount": amount},
                headers={"Idempotency-Key": f"payment:{order_id}"},
                timeout=httpx.Timeout(connect=0.2, read=0.8,
        write=0.2, pool=0.2),
            )
            if 400 <= response.status_code < 500:
                raise PaymentDeclined("Payment was declined or request
        was invalid")
            if response.status_code >= 500:
                raise PaymentUnavailable(f"Payment returned
        {response.status_code}")
            return response.json()["authorization_id"]
        except httpx.TimeoutException as exc:
            raise PaymentUnavailable("Payment timed out") from exc
        except httpx.TransportError as exc:
            raise PaymentUnavailable("Payment transport failed") from
        exc
```

`CircuitBreaker` has three states:

- **closed**: normal calls; failures are counted.
- **open**: fail fast for a short period; protect both services.
- **half-open**: allow a small probe; close only if recovery succeeds.

Use retry only for *transient*, *safe/idempotent* calls. Give a request one end-to-end deadline; do not independently spend 1 second in each of five downstream calls.

Step 3.2: use a bulkhead for a fragile dependency

```
import asyncio
from ..api.errors import DomainError

payment_slots = asyncio.Semaphore(20)

async def authorize_with_bulkhead(client, order_id, total):
    try:
        async with asyncio.timeout(1.2):
            async with payment_slots:
                return await client.authorize(order_id, total)
    except TimeoutError:
        raise DomainError("PAYMENT_UNAVAILABLE", "Try again later",
        503)
    except PaymentUnavailable:
        raise DomainError("PAYMENT_UNAVAILABLE", "Try again later",
        503)
    except PaymentDeclined:
        raise DomainError("PAYMENT_DECLINED", "Payment was declined",
        402)
```

The semaphore is a **local bulkhead**, not a distributed rate limit. It prevents 1,000 incoming requests from creating 1,000 in-flight payment calls per replica. Keep the limit observable and tune it against payment capacity.

Step 3.3: make failures visible

Return `503` plus a safe retry hint when the request cannot proceed. Do not reveal payment provider errors. Emit metrics: request duration, breaker state, downstream timeout count, and in-flight bulkhead slots.

Failure clinic

Bad "fix"	Why it makes the incident worse	Replace it with
retry every exception three times	load triples while a dependency is sick	retry only transport/5xx failures, with jitter and a global deadline
retry `POST /charge` without a key	a timeout may mean the provider already charged	downstream idempotency key based on your order/operation ID
circuit breaker around all errors	bad request/declined card opens breaker	count only dependency availability failures
unbounded `gather()` over 10,000 operations	exhausts connections/memory	bounded concurrency and queues
`except Exception: return {"success": false}`	loses failure classification and observability	map expected exceptions, log unexpected exceptions with trace ID

Exercise: inject `await asyncio.sleep(3)` in payment. Send 50 concurrent order requests. Observe timeout, semaphore limiting, then circuit opening. Remove the delay and observe half-open recovery.

Lab 4 — Let the platform route traffic: gateway and discovery

Problem: the browser/AI client calls every service directly, carries internal addresses, and each service repeats auth, CORS, and rate limiting differently.

Step 4.1: define the gateway boundary — local Compose implementation

Environment for this lab: Docker Compose only. You are moving from Labs 0-3, where the FastAPI process ran on your host and Postgres/Redpanda ran in containers, to a local multi-container system. Kubernetes appears for the first time in Lab 8.

The API gateway is the north-south edge. It performs API authentication, coarse rate limits, request-size limits, routing/versioning, TLS termination, and audit correlation. It should **not** contain order business rules or become a database-backed monolith.

The local request path is deliberately simple:

```
sequenceDiagram
  participant C as curl / AI client
  participant G as Kong localhost:8000
```

```
participant O as order-service:8000
C->>G: POST /api/v1/orders
G->>O: POST /v1/orders
O-->>G: 202 + order_id
G-->>C: 202 + order_id
```

Step 4.1a: add the container image used from this point onward

Create `services/order_service/Dockerfile`. Lab 8 reuses this same immutable image; it does not introduce a second packaging approach.

```
FROM python:3.12-slim
WORKDIR /app
RUN useradd --system --create-home appuser

COPY pyproject.toml uv.lock ./
RUN pip install --no-cache-dir uv && uv sync --frozen --no-dev

COPY services ./services
USER appuser
EXPOSE 8000
CMD ["uv", "run", "uvicorn", "services.order_service.app.main:app", "--
    host", "0.0.0.0", "--port", "8000"]
```

Step 4.1b: run Kong and the service in Compose

Create `infra/.env.compose`. Its hostnames are Compose service names, not laptop hostnames:

```
DATABASE_URL=postgresql+asyncpg://orders:orders@postgres:5432/orders
INVENTORY_URL=http://inventory-service:8000
PAYMENT_URL=http://payment-service:8000
KAFKA_BOOTSTRAP_SERVERS=redpanda:9092
```

Add these services to `infra/compose.yaml` below the existing Postgres and Redpanda services:

```
  order-service:
    build:
      context: ..
      dockerfile: services/order_service/Dockerfile
    env_file: .env.compose
    expose: ["8000"]                # internal only; no direct laptop
        port
    depends_on:
      postgres:
        condition: service_healthy

  inventory-service:
    build:
      context: ..
      dockerfile: services/order_service/Dockerfile
    command: ["uv", "run", "uvicorn",
        "services.mock_dependency.main:app", "--host", "0.0.0.0", "--
        port", "8000"]
    environment:
      DEPENDENCY_NAME: inventory
    expose: ["8000"]

  payment-service:
    build:
      context: ..
      dockerfile: services/order_service/Dockerfile
```

```
    command: ["uv", "run", "uvicorn",
        "services.mock_dependency.main:app", "--host", "0.0.0.0", "--
        port", "8000"]
    environment:
      DEPENDENCY_NAME: payment
    expose: ["8000"]

  kong:
    image: kong:3.7
    environment:
      KONG_DATABASE: "off"
      KONG_DECLARATIVE_CONFIG: /kong/kong.yml
      KONG_PROXY_LISTEN: 0.0.0.0:8000
      KONG_ADMIN_LISTEN: 0.0.0.0:8001
    volumes:
      - ./gateway/kong.yml:/kong/kong.yml:ro
    ports:
      - "8000:8000"                  # client entry point
      - "8001:8001"                  # local inspection only; never
        expose in production
    depends_on:
      - order-service
```

Important

The `order-service` uses `expose`, not `ports`. From this lab onward, the laptop client must enter through Kong. The only exception is temporary debugging with `docker compose exec`.

Step 4.1c: configure Kong with a path that actually matches FastAPI

Create `infra/gateway/kong.yml`:

```
_format_version: "3.0"
services:
  - name: order-service
    url: http://order-service:8000
    routes:
      - name: order-api
        paths: ["/api"]
        strip_path: true
    plugins:
      - name: rate-limiting
        config:
          minute: 60
          policy: local              # local-learning setting; Lab 9
        uses shared Redis policy
      - name: request-size-limiting
        config:
          allowed_payload_size: 1
```

`strip_path: true` is essential here. It maps the external `/api/v1/orders` route to FastAPI's internal `/v1/orders` route. The earlier `strip_path: false` example would have forwarded `/api/v1/orders` and resulted in a FastAPI 404.

Step 4.1d: start and verify the boundary

```
docker compose -f infra/compose.yaml up --build -d
docker compose -f infra/compose.yaml ps
curl -i http://localhost:8000/api/livez
curl -i -X POST http://localhost:8000/api/v1/orders \
  -H 'content-type: application/json' \
```

```
  -H 'Idempotency-Key: order-demo-key-0001' \
  -d '{"customer_id":"11111111-1111-1111-1111-111111111111","lines":
        [{"sku":"SKU-001","quantity":1,"unit_price":"49.90"}]}'
```

Expected result: Kong returns `202` and an order ID. If you call `http://localhost:8000/v1/orders` directly, it should fail because that port belongs to Kong, not the application.

In the service, trust forwarded identity headers only when requests can come exclusively through a gateway/mesh. In production, enforce that with network policy and signed JWT validation; otherwise any caller can forge `X-User-Id`.

Step 4.2: service discovery — Compose now, Kubernetes later

Environment	This course uses it in	How `order-service` finds inventory	What not to do
Docker Compose	**This lab and local labs**	DNS name `http://inventory-service:8000`	hard-code laptop IPs
Kubernetes	**Lab 8 onward**	`http://inventory-service.orders.svc.cluster.local` resolved by CoreDNS	inject individual Pod IPs into configuration
Mesh	**Lab 8 onward**	call the Kubernetes service name; sidecar load-balances healthy endpoints	build a Python registry client alongside the platform registry

For the Compose lab, service names in `compose.yaml` are DNS names on Compose's default network. For Kubernetes, a `Service` gives a stable virtual address while Pods are created and removed; readiness gates which Pods become endpoints. The concept is the same, but the platform implementation differs.

▶ **Why not use Kubernetes discovery in Lab 4?**

Failure clinic

Symptom	Cause	Fix
works locally but returns `Name or service not known` in cluster	Compose service DNS name copied into a different namespace	use fully-qualified service address or correct namespace
service routes to a Pod still starting	liveness exists but readiness does not represent dependency initialization	configure readiness and only return ready when the service can perform its required startup work
gateway says `429`, service dashboards do not show it	request is rejected before FastAPI	monitor gateway metrics/logs as a first-class service
spoofed identity header	service is reachable outside the trusted ingress	validate JWT in service or restrict network paths and use mesh identity

Lab 5 — Decouple the workflow with async messaging and a transactional outbox

Problem: `POST /orders` creates an order in Postgres and then publishes `OrderCreated` to Kafka. If the process dies between those steps, the order exists but shipping/notification never learns about it. If it publishes first and DB fails, consumers act on an order that does not exist.

Step 5.1: write the event in the same transaction

```
CREATE TABLE outbox (
  id UUID PRIMARY KEY,
  aggregate_id UUID NOT NULL,
  event_type TEXT NOT NULL,
  payload JSONB NOT NULL,
  occurred_at TIMESTAMPTZ NOT NULL DEFAULT now(),
  published_at TIMESTAMPTZ
);
CREATE INDEX outbox_unpublished_idx ON outbox (occurred_at) WHERE
        published_at IS NULL;
```

Inside the *same* transaction that inserts the order, allocate the event ID once and persist the complete event envelope:

```
event_id = uuid4()
await session.execute(text("""
  INSERT INTO outbox(id, aggregate_id, event_type, payload)
  VALUES (:id, :order_id, 'OrderCreated', CAST(:payload AS jsonb))
"""), {"id": event_id, "order_id": order_id,
           "payload": dumps({"event_id": str(event_id), "order_id":
        str(order_id),
                             "customer_id": str(command.customer_id),
        "version": 1})})
```

Now a publisher process may safely retry delivery:

```
# services/order_service/app/infrastructure/outbox_publisher.py — use
        SKIP LOCKED so replicas do not publish the same row
        concurrently
from json import dumps

async def publish_batch(session, producer):
    async with session.begin():
        rows = (await session.execute(text("""
          SELECT id, aggregate_id, event_type, payload FROM outbox
          WHERE published_at IS NULL
          ORDER BY occurred_at FOR UPDATE SKIP LOCKED LIMIT 100
        """))).mappings().all()
        for row in rows:
            body = dumps(row["payload"]).encode()
            await producer.send_and_wait(
                "orders.events",
                body,
                key=str(row["aggregate_id"]).encode(),
            )
            await session.execute(
                text("UPDATE outbox SET published_at = now() WHERE id
        = :id"),
```

```
                {"id": row["id"]},
            )
```

Use the aggregate ID, not the event ID, as the Kafka key so all events for one order stay in partition order. The publisher example uses a short database transaction and small batch for learning. For high-volume systems, use a lease/claim strategy or CDC so database locks are not held during broker calls.

For high volume, use CDC (Debezium) to publish the outbox table. The transaction principle remains unchanged.

Step 5.2: accept at-least-once delivery

Kafka producer acknowledgement plus a database update is still not one global atomic transaction. A crash after Kafka accepts an event but before `published_at` commits means the event can be sent twice. Therefore consumers must be idempotent.

```
CREATE TABLE processed_events (
  consumer_name TEXT NOT NULL,
  event_id UUID NOT NULL,
  processed_at TIMESTAMPTZ NOT NULL DEFAULT now(),
  PRIMARY KEY (consumer_name, event_id)
);
```

```
async def consume_shipping(event, session):
    async with session.begin():
        seen = await session.execute(text("""
          INSERT INTO processed_events(consumer_name, event_id)
          VALUES ('shipping', :event_id) ON CONFLICT DO NOTHING
          RETURNING event_id
        """), {"event_id": event["event_id"]})
        if seen.scalar_one_or_none() is None:
            return  # duplicate: acknowledge safely
        # Create shipment with an order_id unique constraint.
```

Failure clinic

Symptom	Why	Fix
event missing after a restart	DB commit and publish were two independent actions	transactional outbox + publisher/CDC
customer receives two confirmations	delivery is at least once	inbox/dedupe table and idempotent business operation
one poison event blocks a partition forever	consumer retries an invalid schema/event infinitely	bounded retry topics, dead-letter topic, alert and repair runbook
events arrive out of order for an order	keys were random / topic partitions reorder globally	use `order_id` as Kafka message key; version the aggregate
consumers break after producer deployment	event was an undocumented internal JSON blob	use versioned event envelopes and compatibility rules; never rename/delete required fields casually

Lab 6 — Coordinate distributed work with a saga

Problem: “create order → reserve inventory → authorize payment → create shipment” is not a single database transaction. Two-phase commit across services is slow, fragile, and rarely appropriate. We need a business-level sequence with explicit compensations.

Step 6.1: model the saga states

```
stateDiagram-v2
  [*] --> PENDING
  PENDING --> STOCK_RESERVED: reserve succeeds
  STOCK_RESERVED --> PAYMENT_AUTHORIZED: payment succeeds
  PAYMENT_AUTHORIZED --> CONFIRMED: shipment created
  STOCK_RESERVED --> CANCELLED: payment fails / release stock
  PAYMENT_AUTHORIZED --> CANCELLED: shipment fails / void payment,
release stock
```

Store saga state durably in the Order database. The workflow may be triggered by events; it must survive restarts and be safe to retry.

```python
async def advance_order(order_id, inventory, payment, shipping, repo):
    order = await repo.lock_for_update(order_id)
    if order.status == "PENDING":
        order.reservation_id = await inventory.reserve(order_id,
        order.lines)
        order.status = "STOCK_RESERVED"
        await repo.save(order)

    if order.status == "STOCK_RESERVED":
        try:
            order.authorization_id = await payment.authorize(order_id,
        order.total)
            order.status = "PAYMENT_AUTHORIZED"
            await repo.save(order)
        except PaymentDeclined:
            await inventory.release(order.reservation_id)  #
        compensation, itself idempotent
            order.status = "CANCELLED"
            await repo.save(order)
            return

    if order.status == "PAYMENT_AUTHORIZED":
        try:
            order.shipment_id = await shipping.create(order_id,
        order.lines)
            order.status = "CONFIRMED"
        except ShippingUnavailable:
            await payment.void(order.authorization_id)
            await inventory.release(order.reservation_id)
            order.status = "CANCELLED"
        await repo.save(order)
```

This is an **orchestrated saga**: one component owns the state machine. Choreography—each service reacts to events—works for simple flows, but becomes difficult to reason about when the compensation path spans many services.

Step 6.2: distinguish a compensation from rollback

`release inventory` cannot erase history. It creates a new business fact. A payment authorization can be voided; a settled payment needs a refund. Design compensations before the forward action and document the “irreversible” boundary.

Failure clinic

Scenario	Correct response
reserve request timed out; inventory may have reserved	retry using the same operation ID, then query by operation ID before assuming failure
order coordinator crashes after payment authorization	replay saga from durable state; make `authorize(order_id)` idempotent
release stock fails after a declined card	mark order `COMPENSATION_PENDING`, retry asynchronously, page on age/SLO; do not lie that it is cleanly cancelled
shipment created but confirmation response was lost	lookup shipment by `order_id` rather than create another shipment
payment has settled	use refund policy instead of void; require a human/business rule if refund cannot be automatic

Exercise: make shipping return 503 after payment success. Show the order entering `COMPENSATION_PENDING`, then recover it after shipping/payment services come back.

Lab 7 — Use CQRS and event sourcing for the right problem

Problem: the transactional `orders` table handles command consistency well, but support dashboards need a denormalized, filterable timeline: "all orders delayed after payment authorization." Complex reports now hurt command latency and every table change breaks read views.

Step 7.1: apply CQRS before event sourcing

CQRS means **separate write and read models**, not necessarily separate databases or microservices. The command side protects invariants. The query side is optimized for questions.

```
CREATE TABLE order_summary (
  order_id UUID PRIMARY KEY,
  customer_id UUID NOT NULL,
  status TEXT NOT NULL,
  total NUMERIC(10,2) NOT NULL,
  payment_status TEXT,
  shipment_status TEXT,
  updated_at TIMESTAMPTZ NOT NULL
);
```

A projection consumer listens to versioned order events and upserts `order_summary`. `GET /v1/orders/{id}` can read this model. Tell callers its data is **eventually consistent**—a just-accepted order might not appear in a dashboard for seconds.

```
async def apply_event(event, session):
    # Do dedupe/version checks first (see Lab 5).
    if event["type"] == "OrderCreated":
        await session.execute(text("""
          INSERT INTO order_summary(order_id, customer_id, status,
        total, updated_at)
          VALUES (:id, :customer_id, 'PENDING', :total, now())
          ON CONFLICT (order_id) DO NOTHING
```

```
        """), event["data"])
    elif event["type"] == "PaymentAuthorized":
        await session.execute(text("UPDATE order_summary SET
        payment_status='AUTHORIZED', updated_at=now() WHERE
        order_id=:id"), event["data"])
```

Step 7.2: event sourcing is a stronger choice

In event sourcing, the event stream is the source of truth; current order state is rebuilt by applying events.

```
CREATE TABLE order_events (
  order_id UUID NOT NULL,
  version INTEGER NOT NULL,
  event_id UUID NOT NULL UNIQUE,
  event_type TEXT NOT NULL,
  data JSONB NOT NULL,
  occurred_at TIMESTAMPTZ NOT NULL DEFAULT now(),
  PRIMARY KEY (order_id, version)
);
```

Append with optimistic concurrency:

```
INSERT INTO order_events(order_id, version, event_id, event_type,
        data)
VALUES (:order_id, :expected_version + 1, :event_id, 'StockReserved',
        :data);
```

If another command already appended version 5, the primary-key collision tells you your state was stale. Reload events, re-evaluate the command, and either retry or reject.

Do not use event sourcing merely because it sounds advanced. It earns its complexity when immutable audit history, temporal reconstruction, and multiple independent projections are central product needs (financial ledger, compliance, complex order lifecycle). For many services, the Lab 2 transactional model plus Lab 5 outbox is the better default.

Failure clinic

Symptom	Cause	Fix
dashboard says PENDING after order is confirmed	projection lag or failed consumer	expose last-applied offset/age; replay idempotent projection; set freshness SLO
replay changes the result after code deployment	event handler logic is not versioned/tested	keep events immutable, add upcasters/versions, test historical replay
two commands race and overwrite an order	no expected version check	optimistic concurrency on aggregate version
event store grows and rehydration is slow	loading full history per command	snapshots are a cache; validate snapshot version then apply newer events

Lab 8 — Production platform: containers, Kubernetes, sidecars, service mesh

Problem: each service must implement mTLS, tracing, retries, traffic shifting, and network policy perfectly. That creates inconsistent reliability and security code in every repository.

Step 8.0: create the optional local Kubernetes platform

Complete this once, only after Labs 0-7 work in Compose. If you use Minikube, translate the `kind` image-loading command in Step 8.1; the Kubernetes manifests remain the same.

```
kind create cluster --name workshop
istioctl install --set profile=demo -y
kubectl get nodes
kubectl get pods -n istio-system
```

Expected result: the cluster has one Ready control-plane node and the Istio control-plane Pods are Running. If `istioctl` is unavailable, install it from the official Istio release matching the version you intend to use; do not continue with the mesh exercises without a working control plane.

Step 8.1: promote the same image built in Lab 4

Lab 4 already created the **services/order_service/Dockerfile** so learners do not maintain separate "Compose" and "Kubernetes" images. Build the identical source once, then deploy its immutable digest to each environment.

```
docker build -t order-service:workshop -f
        services/order_service/Dockerfile .

# Choose exactly one local-cluster loading command.
kind load docker-image order-service:workshop --name workshop
# minikube image load order-service:workshop
```

For a real registry, replace **order-service:workshop** with a versioned image digest. Inject configuration/secrets at runtime. Never bake environment files, API keys, or database URLs into the image.

Step 8.2: deploy statelessly

Create the namespace and inject the sidecar **before** creating the Deployment:

```
kubectl create namespace orders
kubectl label namespace orders istio-injection=enabled
kubectl -n orders create secret generic order-service-secrets \
  --from-
        literal=DATABASE_URL='postgresql+asyncpg://placeholder:placeholder@placeholder:543
        \
  --from-literal=INVENTORY_URL='http://inventory-service' \
  --from-literal=PAYMENT_URL='http://payment-service' \
  --from-literal=KAFKA_BOOTSTRAP_SERVERS='placeholder:9092'
```

Note

This Lab 8 cluster exercise verifies Pod lifecycle, discovery, sidecar injection, and traffic policy. It does **not** move Postgres/Redpanda into Kubernetes; keep the stateful Labs 2-7 local in Compose. The placeholder URLs are safe because the current health endpoints do not call a dependency. Do not use this placeholder configuration for a real workload.

```
# k8s/base/order-service.yaml
apiVersion: apps/v1
kind: Deployment
metadata: { name: order-service }
```

```yaml
spec:
  replicas: 3
  selector: { matchLabels: { app: order-service } }
  template:
    metadata: { labels: { app: order-service } }
    spec:
      containers:
        - name: app
          image: order-service:workshop
          imagePullPolicy: IfNotPresent
          ports: [{ containerPort: 8000 }]
          envFrom: [{ secretRef: { name: order-service-secrets } }]
          resources:
            requests: { cpu: "250m", memory: "512Mi" }
            limits: { cpu: "1", memory: "1Gi" }
          startupProbe:
            httpGet: { path: /livez, port: 8000 }
            failureThreshold: 30
            periodSeconds: 2
          livenessProbe:
            httpGet: { path: /livez, port: 8000 }
          readinessProbe:
            httpGet: { path: /readyz, port: 8000 }
---
apiVersion: v1
kind: Service
metadata: { name: order-service }
spec:
  selector: { app: order-service }
  ports: [{ port: 80, targetPort: 8000 }]
---
apiVersion: autoscaling/v2
kind: HorizontalPodAutoscaler
metadata: { name: order-service }
spec:
  scaleTargetRef:
    apiVersion: apps/v1
    kind: Deployment
    name: order-service
  minReplicas: 2
  maxReplicas: 6
  metrics:
    - type: Resource
      resource:
        name: cpu
        target:
          type: Utilization
          averageUtilization: 70
```

```
kubectl -n orders apply -f k8s/base/order-service.yaml
kubectl -n orders get pods,svc,hpa
kubectl -n orders get pod -l app=order-service -o
        jsonpath='{.items[0].spec.containers[*].name}'
kubectl -n orders port-forward service/order-service 8080:80
# In another terminal:
curl -i http://localhost:8080/livez
```

Expected result: the container list includes **app istio-proxy**, at least two Pods become ready, and **/livez** returns **200**. If **istio-proxy** is absent, stop and verify that Istio is installed and the namespace label existed before Pod creation.

The HPA is included to show the resource-scaling contract. Run `kubectl -n orders get hpa`. If CPU shows `<unknown>`, your local cluster has no Metrics Server; install/enable it before trying to validate CPU scaling. Lab 9 explains why queue lag and concurrency limits are often better scaling signals for asynchronous workers.

Step 8.3: understand the sidecar pattern

A **sidecar** is a helper container running beside the application in the same Pod. It shares lifecycle/network namespace but owns a cross-cutting concern. Examples: Envoy proxy, log shipper, secret agent.

The service mesh injects an Envoy sidecar. Calls from FastAPI to `inventory-service` are transparently intercepted; Envoy can enforce mTLS, collect request metrics/traces, apply connection pooling, and load-balance healthy endpoints.

Important boundary: do not apply retry both in FastAPI *and* in the mesh without a single retry budget. Two layers of three retries can create nine requests; add a gateway retry and it can become 27.

Step 8.4: translate the local gateway path to an Istio ingress gateway

Kong is the local Compose gateway in Lab 4. In this Kubernetes lab, use Istio's ingress gateway so you can observe one platform-owned north-south entry point alongside the sidecar mesh. In a real platform, choose the organization-standard gateway; do not expose both Kong and Istio gateway for the same API path without a clear reason.

```
# k8s/istio/order-ingress.yaml
apiVersion: networking.istio.io/v1
kind: Gateway
metadata: { name: orders-gateway }
spec:
  selector:
    istio: ingressgateway
  servers:
    - port: { number: 80, name: http, protocol: HTTP }
      hosts: ["*"]
---
apiVersion: networking.istio.io/v1
kind: VirtualService
metadata: { name: order-service-edge }
spec:
  hosts: ["*"]
  gateways: [orders-gateway]
  http:
    - match:
        - uri: { prefix: "/api" }
      rewrite:
        uriRegexRewrite:
          match: "^/api/(.*)"
          rewrite: "/\\1"
      route:
        - destination:
            host: order-service.orders.svc.cluster.local
            port: { number: 80 }

kubectl -n orders apply -f k8s/istio/order-ingress.yaml
kubectl -n istio-system port-forward service/istio-ingressgateway
        8080:80
# In another terminal:
curl -i http://localhost:8080/api/livez
```

Expected result: the ingress gateway rewrites `/api/livez` to the service's `/livez` endpoint and returns `200`. This is the Kubernetes equivalent of Lab 4's external `/api` boundary.

Step 8.5: make mesh traffic policy explicit

```yaml
# k8s/istio/payment-policy.yaml
apiVersion: networking.istio.io/v1
kind: DestinationRule
metadata: { name: payment-service }
spec:
  host: payment-service
  trafficPolicy:
    tls: { mode: ISTIO_MUTUAL }
    connectionPool:
      http: { http1MaxPendingRequests: 100, maxRequestsPerConnection:
        20 }
    outlierDetection:
      consecutive5xxErrors: 5
      interval: 5s
      baseEjectionTime: 30s
---
apiVersion: networking.istio.io/v1
kind: VirtualService
metadata: { name: payment-service }
spec:
  hosts: [payment-service]
  http:
    - timeout: 1s
      route: [{ destination: { host: payment-service } }]
```

This is circuit-breaking-like **traffic protection** at the proxy layer. It does not replace application-level business handling: FastAPI still decides whether to queue the order, compensate, or report a retryable error.

Failure clinic

Symptom	Why	Fix
Pods restart continuously during a database outage	liveness probe depends on external DB	liveness checks process; readiness can fail dependency gating if appropriate
`OOMKilled` even though CPU looks fine	memory limit too low / unbounded concurrency	set realistic requests/limits, profile memory, bound queues and fan-out
mTLS errors after mesh enablement	one workload is not enrolled or policy mode mismatches	inspect sidecar injection, peer authentication and destination TLS mode
503 `UF` / `upstream reset` from Envoy	proxy timeout, connection pool, or endpoints issue	check Envoy access logs/metrics plus Kubernetes endpoints—not only app logs
retry storm after mesh rollout	both app and mesh retry	assign retry ownership per call path and measure attempts

Capstone — Run a controlled failure game day

Work in pairs. For each scenario, state (1) user-visible behavior, (2) expected logs/metrics/traces, (3) automatic recovery, and (4) operator action.

Injected failure	Expected design behavior
Send identical `POST /orders` three times concurrently	one persisted order; same order ID returned; no duplicate event/business action
Payment waits 5 seconds	order calls fail within deadline; bulkhead protects other requests; breaker opens; no duplicate charge
kill service after DB commit before publish	outbox publisher later emits the event
deliver `OrderCreated` twice	consumer dedupe makes one shipment/notification
shipping fails after authorization	saga voids payment and releases stock, or marks compensation pending for retry
restart every order Pod	requests continue through ready replicas; durable order/saga state survives
roll out a bad payment version	mesh/gateway canary or rollback limits blast radius; telemetry identifies increased 5xx

Completion rubric

- Every unsafe command has idempotency semantics.
- Every remote call has timeout, classification, and bounded concurrency.
- Events are durably recorded before asynchronous publication.
- Consumers are safe under duplicate delivery and expose poison-message handling.
- Each saga step and compensation is durable and idempotent.
- Read-model eventual consistency is explicit to callers.
- The app is stateless; health probes are correctly scoped.
- Gateway, Kubernetes, and mesh responsibilities are not duplicated blindly in FastAPI.
- Logs, metrics, and traces answer: "which order, which saga state, which downstream call, and what failed?"

Instructor notes and extension path

Suggested checkpoints

1. **After Lab 2:** ask why storing order state in Redis alone is unsafe.
2. **After Lab 3:** ask why "retry on any error" can turn a partial outage into a full outage.
3. **After Lab 5:** ask why Kafka does not give business exactly-once processing by itself.
4. **After Lab 6:** ask learners to write compensations before forward steps.
5. **After Lab 8:** ask what should be app code versus a platform policy.

Production additions deliberately left as follow-on labs

- OAuth2/OIDC and service-to-service workload identity; authorization policies per command
- distributed tracing with OpenTelemetry collector, structured logging and Prometheus/Grafana alerting
- consumer schema registry and contract tests
- database migration rollout/rollback strategy and expand–migrate–contract changes
- rate limiting with a distributed store, abuse controls, WAF, and tenant quotas
- OpenAPI generation/client SDKs, load tests (k6/Locust), chaos experiments, and SLO/error-budget design

- a durable workflow engine such as Temporal for long-running sagas that exceed the scope of one service

A pragmatic decision guide

Need	Start with	Add only when
reliable API write	Postgres transaction + idempotency key	always
notify other services	transactional outbox + at-least-once consumer	always for cross-service events
distributed work	explicit saga	there is a true multi-service business transaction
read scaling/query flexibility	CQRS projection	command data model no longer serves query needs
immutable audit/replay	event sourcing	audit/time-travel is primary, not merely interesting
service-to-service protection	Kubernetes Service + timeouts	mesh when platform can operate it well and cross-cutting policy must be uniform

The core lesson is not “use every pattern.” It is to make each failure mode explicit, select the smallest mechanism that contains it, and prove it under controlled failure.

Advanced Production Extension — From Reliable Services to Operable Systems

The original one-day workshop covers the core request, data, and workflow patterns. The following **six hands-on extension labs** turn it into a two-day course and address the operational patterns that determine whether a distributed system remains healthy under real traffic, bad deploys, and partial outages.

Advanced-day plan (Labs 9-14)

Time	Lab	Outcome
09:30-10:25	9. Admission control	protect critical traffic during a burst
10:25-11:20	10. Event operations	recover from poison messages and evolve contracts
11:30-12:20	11. Observability and SLOs	trace user impact across sync and async work
13:15-14:05	12. Zero trust	enforce user, workload, and tenant boundaries
14:05-14:55	13. Safe delivery	deploy compatible changes and recover safely
15:05-15:55	14. Data scale and recovery	manage caches, ownership, partitions, and DR
15:55-16:30	Advanced capstone	operate through a traffic and release incident

Extension lab	Pattern added	Failure it prevents
9	Admission control, rate limiting, load shedding, queue-based load leveling	a traffic burst exhausts every worker and downstream dependency
10	Retry topics, DLQ, schema evolution, contract tests	a poison event blocks a consumer or a producer deployment breaks consumers
11	Observability, SLOs, alerting	engineers cannot identify which dependency or tenant caused a failure
12	Zero trust, service identity, authorization policy	an internal caller forges identity or reaches an operation it must not use
13	Safe delivery, feature flags, expand-migrate-contract	a backward-incompatible release or migration causes downtime
14	Cache-aside, data ownership, partitioning, DR decisions	database overload, cache stampede, shared-database coupling, or unclear recovery design

Lab 9 — Admit only the work the system can safely handle

Problem: circuit breakers protect an unhealthy downstream service, but a surge of valid requests can still fill every worker, connection pool, and queue before the breaker opens. A healthy system needs a deliberate answer to: *which work do we accept now, defer, or reject?*

Step 9.1: separate three controls

Control	Decision	Typical location
Rate limit	"Has this tenant/user exceeded an agreed quota?"	gateway or Redis-backed limiter
Concurrency limit	"Can this service start one more expensive operation?"	service/mesh worker pool
Load shedding	"Is protecting the system more important than accepting this non-critical request?"	gateway and service

Do not treat them as the same thing. A tenant can remain within its 60 requests/minute quota yet still trigger 60 expensive LLM, payment, or database operations simultaneously.

Step 9.2: apply a distributed rate limit at the gateway

Use the gateway or Envoy rate-limit service for the first protection layer. The key must represent a real fairness boundary: tenant ID, API key, user ID, or client application—not just source IP.

```
# Conceptual gateway policy: one shared Redis-backed bucket per tenant
plugins:
  - name: rate-limiting-advanced
    config:
      limit: [120]
      window_size: [60]
```

```
      identifier: credential
      strategy: redis
      retry_after_jitter_max: 3
```

Return `429 Too Many Requests` with `Retry-After`. Never silently queue an interactive request for minutes; callers need an explicit asynchronous job API for that experience.

Step 9.3: bound expensive in-process work

```python
# services/order_service/app/application/admission.py
import asyncio
from fastapi import HTTPException

expensive_work_slots = asyncio.Semaphore(25)

async def run_expensive_work(operation):
    try:
        async with asyncio.timeout(0.05):
            async with expensive_work_slots:
                return await operation()
    except TimeoutError:
        # The service is deliberately refusing work before it causes a
        wider outage.
        raise HTTPException(503, "System busy. Retry shortly.",
        headers={"Retry-After": "2"})
```

Use a separate limit per dependency or workload class. Checkout may deserve reserved capacity; report generation or a bulk re-index request should not consume it.

Step 9.4: turn non-interactive work into a queue

Example: a customer requests a 100,000-order export. Do not keep an HTTP connection open while the API scans data. Persist a job, publish `ExportRequested`, and return `202` plus a job URL.

```python
@router.post("/exports", status_code=202)
async def request_export(body = Body(...)):
    job_id = create_export_job(body)       # durable database row:
        QUEUED
    publish_outbox_event("ExportRequested", {"job_id": job_id})
    return {"job_id": job_id, "status_url": f"/v1/exports/{job_id}"}

# Worker: limited consumer concurrency gives the system a sustainable
        drain rate.
async def handle_export(event):
    mark_job_running(event["job_id"])
    file_url = await build_export_file(event["job_id"])
    mark_job_complete(event["job_id"], file_url)
```

This is **queue-based load leveling**. The queue absorbs a burst; worker concurrency controls drain rate. It is not a license for infinite backlog: monitor oldest message age and reject/defer work before promised completion times become impossible.

Failure clinic

Symptom	Cause	Fix
every Pod is at 100% CPU and even `/livez` is slow	unlimited expensive work entered the service	local concurrency limits, gateway quotas, and fast load shedding

Symptom	Cause	Fix
rate limit resets when a gateway replica restarts	in-memory gateway counter	use Redis or a dedicated distributed rate-limit service for a global tenant quota
export queue grows for hours	arrival rate exceeds worker drain rate	autoscale consumers on lag, cap accepted jobs, communicate expected completion, add per-tenant fairness
one tenant consumes all workers	single global queue and FIFO scheduling	partition quotas/queues by tenant or priority; reserve capacity for critical work
clients retry `503` immediately	no retry contract or jitter	send `Retry-After`, document exponential backoff with jitter, make commands idempotent

Exercise: submit 100 export jobs while workers process two at a time. Track queue depth, oldest-message age, rejection count, and completion latency. Decide at what queue age the API should stop accepting new low-priority exports.

Lab 10 — Make event-driven systems recoverable and evolvable

Problem: an event can fail forever because of corrupt data, an unavailable third party, or a bug. A producer also evolves faster than its consumers. Without bounded retries, dead-letter handling, and compatibility rules, one message can stall a partition or one release can break every consumer.

Step 10.1: use an explicit event envelope

```
{
  "event_id": "8bd1...",
  "event_type": "OrderCreated",
  "schema_version": 1,
  "occurred_at": "2026-10-29T10:00:00Z",
  "correlation_id": "request-7af...",
  "data": {
    "order_id": "o-123",
    "customer_id": "c-456",
    "total": "49.90"
  }
}
```

The envelope gives consumers the fields they need for dedupe, tracing, routing, and version selection. It is a public contract between independently deployed services—not a Python object serialized for convenience.

Step 10.2: classify failures before retrying

```
async def process_message(event):
    try:
        await create_shipment(event["data"])
        return "success"
    except InventoryTemporarilyUnavailable:
        return "retry"
    except InvalidAddress:
        return "business_failure"
```

```
    except Exception:
        return "unknown_failure"

async def consume(event, attempt):
    outcome = await process_message(event)
    if outcome == "success":
        return
    if outcome == "retry" and attempt < 5:
        await publish("orders.retry.5m", {"event": event, "attempt":
        attempt + 1})
        return
    await publish("orders.dlq", {
        "event": event,
        "attempt": attempt,
        "reason": outcome,
    })
```

Use delayed retry topics/queues such as `retry.1m`, `retry.5m`, and `retry.30m`; do **not** block a Kafka consumer with `sleep(300)`. A DLQ is not a trash can. It needs an owner, dashboard, alert threshold, repair workflow, and a safe replay tool.

Step 10.3: evolve additively first

Safe default rules:

- Add optional fields; do not rename, delete, or change the meaning of existing required fields.
- Consumers ignore unknown fields and supply defaults for omitted optional fields.
- Version an event only for a genuine incompatible semantic change.
- Keep old producers/consumers working during the deployment overlap.

```
def normalize_order_created(event):
    version = event.get("schema_version", 1)
    data = event["data"]

    if version == 1:
        # Version 1 did not include currency; preserve the documented
        default.
        data["currency"] = "USD"
    if version not in [1, 2]:
        raise ValueError("Unsupported OrderCreated version")
    return data
```

Step 10.4: test the contract in CI

```
# Keep representative historical events in tests/contracts/.
async def test_shipping_accepts_order_created_v1():
    event = load_json("tests/contracts/order-created-v1.json")
    data = normalize_order_created(event)
    assert data["currency"] == "USD"

async def test_shipping_accepts_order_created_v2():
    event = load_json("tests/contracts/order-created-v2.json")
    data = normalize_order_created(event)
    assert data["currency"] == "INR"
```

At larger scale use a schema registry (Avro, Protobuf, or JSON Schema) and block incompatible producer changes in CI. The schema registry does not replace semantic tests: a field can remain syntactically compatible while its business meaning changes.

Failure clinic

Symptom	Cause	Fix
a partition has growing lag and one event is logged repeatedly	poison event causes infinite retry	bounded retries, retry topic, DLQ, operator repair/replay flow
DLQ grows unnoticed	no ownership/SLO	alert on DLQ count and age; assign a service owner and runbook
new producer breaks old consumer	renamed/deleted field during rolling deploy	additive change, versioned event, compatibility tests
replay creates duplicate shipments	replay tool bypasses normal consumer dedupe	keep event IDs and idempotency checks active for all replays
retry message changes order	retry recomputes data from the current database	retry the original immutable command/event with an operation ID

Lab 11 — Observe request paths, not isolated services

Problem: logs say "payment timeout," but no one can answer which customer request caused it, whether it affected one tenant or every request, how often it occurs, or whether the user-visible objective is violated.

Step 11.1: carry a trace across every hop

```python
# services/order_service/app/observability.py
from opentelemetry import trace
from opentelemetry.instrumentation.fastapi import FastAPIInstrumentor
from opentelemetry.instrumentation.httpx import
        HTTPXClientInstrumentor
from opentelemetry.sdk.trace import TracerProvider
from opentelemetry.sdk.trace.export import BatchSpanProcessor
from opentelemetry.exporter.otlp.proto.grpc.trace_exporter import
        OTLPSpanExporter

def configure_observability(app):
    provider = TracerProvider()
    provider.add_span_processor(BatchSpanProcessor(OTLPSpanExporter()))
    trace.set_tracer_provider(provider)
    FastAPIInstrumentor.instrument_app(app)
    HTTPXClientInstrumentor().instrument()
```

OpenTelemetry propagates `traceparent` on HTTP calls. Include the current trace/correlation ID in Kafka headers too, then consumer spans can join the same end-to-end order timeline.

Step 11.2: use structured logs and meaningful metrics

```python
import structlog

log = structlog.get_logger()
```

```python
async def authorize_order(order_id, customer_id, total):
    log.info("payment_authorization_started", order_id=order_id,
        customer_id=customer_id)
    try:
        authorization_id = await payment.authorize(order_id, total)
        log.info("payment_authorization_succeeded", order_id=order_id)
        return authorization_id
    except Exception:
        log.exception("payment_authorization_failed",
        order_id=order_id)
        raise
```

Record **RED metrics** for each API: Rate, Errors, Duration. Record queue depth/oldest age for consumers and breaker state/concurrency for dependencies. Avoid a metric label such as `order_id` or `customer_id`; it creates unbounded time-series cardinality and can overload Prometheus.

Step 11.3: define service-level objectives

Example checkout SLO:

Signal	Objective	Alert condition
Availability	99.9% of valid `POST /orders` requests accepted monthly	error-budget burn is 10x normal over 1 hour
Latency	95% accepted in under 700 ms	p95 exceeds 700 ms for 15 minutes
Async completion	99% of accepted orders reach terminal state in under 5 minutes	oldest order saga exceeds 5 minutes
Event health	99.9% events leave outbox in under 60 seconds	outbox lag or DLQ age breaches target

Alert on user impact and fast budget burn—not every single 500. An isolated failed request is a log/tracing event; an alert means action is required now.

Failure clinic

Symptom	Cause	Fix
each service has a different request ID	correlation IDs are generated per hop	use W3C trace propagation; generate only at the trusted edge if absent
Prometheus memory grows without bound	high-cardinality labels such as user/order ID	retain IDs in logs/traces, not metric labels
dashboards look healthy while orders stay pending	API metrics omit asynchronous workflow health	add saga-age, outbox-lag, consumer-lag, and DLQ metrics
alerts cause noise and are ignored	alerts are based on raw errors rather than SLO burn	alert on error budget and actionable symptoms

Exercise: force payment timeouts, then use one trace ID to find the gateway request, order span, payment call, breaker state, and final saga outcome.

Lab 12 — Apply zero-trust identity and authorization

Problem: network location is treated as identity. Any Pod that can reach `order-service` can send a forged `X-User-Id` header or invoke a refund endpoint. A service mesh encrypts traffic, but encryption alone does not decide who may do what.

Step 12.1: separate human, workload, and permission identity

Identity	Example	Verification
End user	customer placing an order	gateway validates OIDC access token
Workload	shipping service consuming `OrderCreated`	mesh workload identity / mTLS certificate
Permission	support agent requests refund	scopes, roles, tenant policy, business authorization

The gateway verifies external JWTs and passes trusted claims only through an authenticated internal path. A sensitive service should also validate the token or receive a short-lived signed internal identity token; do not blindly trust arbitrary headers.

Step 12.2: enforce permissions in the application

```python
# services/order_service/app/api/security.py
from fastapi import Depends, HTTPException

def current_principal():
    # Production version: validate issuer, audience, signature and
        expiry using cached JWKS keys.
    # This placeholder assumes a verified gateway token was converted
        to a trusted principal.
    return {"subject": "user-123", "tenant_id": "tenant-a", "scopes":
        ["orders:write"]}

def require_scope(scope):
    def check(principal = Depends(current_principal)):
        if scope not in principal["scopes"]:
            raise HTTPException(403, "Missing required permission")
        return principal
    return check

@router.post("/{order_id}/cancel")
async def cancel_order(order_id, principal =
        Depends(require_scope("orders:cancel"))):
    return await order_service.cancel(order_id,
        principal["tenant_id"])
```

Authorization must include the resource boundary. Having `orders:cancel` is insufficient if a support agent from tenant A can cancel tenant B's order. The domain lookup must constrain by tenant/ownership.

Step 12.3: restrict network paths with mesh policy

```yaml
apiVersion: security.istio.io/v1
kind: AuthorizationPolicy
metadata:
  name: payment-only-from-order-service
spec:
  selector:
    matchLabels: { app: payment-service }
```

```yaml
  rules:
    - from:
        - source:
            principals: ["cluster.local/ns/orders/sa/order-service"]
      to:
        - operation:
            methods: ["POST"]
            paths: ["/authorizations"]
```

Use a secret manager and workload identity to obtain secrets dynamically. Do not put API keys in images, ConfigMaps, Git, log messages, traces, or exception responses. Rotate secrets and signing keys without downtime.

Failure clinic

Symptom	Cause	Fix
caller sends `X-User-Id: admin`	service treats a header as proof of identity	validate signed tokens; restrict direct service access
valid JWT for tenant A reads tenant B data	authorization checks scope but not resource ownership	include tenant/ownership predicate in every data access path
mesh mTLS enabled but unauthorized API call succeeds	mTLS authenticates workload, not operation permission	add mesh authorization policy and app-level business authorization
key rotation causes all requests to fail	JWKS/secret cache only knows one key	cache by key ID and retain old verification keys during overlap

---

Lab 13 — Release safely when services and schemas evolve independently

Problem: deploys are rolling. For some period, old and new Pods, consumers, and database code run together. A release that requires every component to switch at the same instant is not a production release strategy.

Step 13.1: use expand-migrate-contract for database changes

Example: replace `orders.customer_email` with `customer_id`.

```sql
-- Release A: EXPAND. Old code still works.
ALTER TABLE orders ADD COLUMN customer_id UUID NULL;

-- Release B: MIGRATE. New code writes both fields; a backfill job
        fills old rows.
UPDATE orders SET customer_id = customer_lookup(email)
WHERE customer_id IS NULL;

-- Release C: CONTRACT, only after every reader uses customer_id and
        verification is complete.
ALTER TABLE orders DROP COLUMN customer_email;
```

Never combine a destructive schema change with the first deployment that stops using it. The same rule applies to event fields and external API versions.

Step 13.2: use a feature flag for behavior changes

```python
async def select_payment_path(order):
    if feature_flags.enabled("payment-v2",
        tenant_id=order["tenant_id"]):
        return await payment_v2.authorize(order)
    return await payment_v1.authorize(order)
```

Feature flags need owners, expiry dates, audit history, and a safe default. A permanent forest of flags becomes hidden distributed configuration and makes incidents harder to debug.

Step 13.3: canary traffic before full rollout

```yaml
apiVersion: networking.istio.io/v1
kind: VirtualService
metadata: { name: order-service }
spec:
  hosts: [order-service]
  http:
    - route:
        - destination: { host: order-service, subset: stable }
          weight: 95
        - destination: { host: order-service, subset: canary }
          weight: 5
```

Promote only after comparing canary versus stable on request errors, latency, outbox lag, DLQ rate, and business outcomes such as payment authorization success. A technical `200` can still represent a broken order workflow.

Step 13.4: drain before termination

```yaml
spec:
  terminationGracePeriodSeconds: 45
  containers:
    - name: app
      lifecycle:
        preStop:
          exec:
            command: ["/bin/sh", "-c", "sleep 10"]
```

The readiness endpoint must turn unhealthy before process exit so Kubernetes and the mesh stop routing new traffic. The application then stops consuming new messages, finishes in-flight work within a bounded time, commits offsets/transactions, and closes connections.

Failure clinic

Symptom	Cause	Fix
canary has 200s but order completion drops	only HTTP status is checked	promotion metrics include async workflow and business KPIs
migration blocks writes for minutes	destructive DDL on a large table during peak traffic	use online migration techniques, backfill jobs, and expand-migrate-contract
shutdown duplicates work	consumer exits before idempotent result/offset is safely committed	stop intake first, finish bounded work, retain idempotency on restart

Symptom	Cause	Fix
feature flag becomes permanent and unknown	no ownership or expiry	require owner, purpose, expiration, and deletion ticket

Lab 14 — Scale data deliberately: caches, ownership, partitions, recovery

Problem: adding replicas is easy until every replica reads the same hot data, cache expiry causes a database stampede, and several services directly modify the same tables. At larger scale, data boundaries—not HTTP routes—determine autonomy and reliability.

Step 14.1: use cache-aside only for safely stale reads

```
async def get_catalog_item(sku):
    key = f"catalog:{sku}"
    cached = await redis.get(key)
    if cached:
        return json.loads(cached)

    item = await catalog_repository.get(sku)
    if item is None:
        return None

    await redis.set(key, json.dumps(item), ex=60)
    return item
```

Cache-aside is appropriate for product catalog, configuration, and precomputed summaries. Do not use it as the primary authority for payment balance, stock reservation, or an order's current saga state without carefully defined consistency rules.

Step 14.2: prevent cache stampedes

```
import asyncio

refresh_slots = {}

async def get_catalog_item_singleflight(sku):
    if await redis.get(f"catalog:{sku}"):
        return await get_catalog_item(sku)

    lock = refresh_slots.setdefault(sku, asyncio.Lock())
    async with lock:
        # Recheck: another request may have populated it while this
        request waited.
        return await get_catalog_item(sku)
```

This local "single-flight" lock prevents a stampede only inside one replica. For cross-replica hot keys, prefer probabilistic early refresh, stale-while-revalidate, or a carefully bounded distributed lease. Never use a distributed lock as the first response to ordinary concurrency; it adds its own availability failure mode.

Step 14.3: make ownership explicit

Data	Owning service	How other services use it
Order and saga state	order-service	API or `Order*` events
Stock reservation	inventory-service	reservation API and `Stock*` events
Payment authorization	payment-service	payment API and `Payment*` events
Search/dashboard view	reporting-service	projections fed by events

No service writes another service's database tables. A shared database makes a local schema change a hidden distributed deployment. Use an anti-corruption layer at boundaries: translate external/legacy concepts into your own domain commands rather than allowing their model to leak throughout the system.

Step 14.4: choose partitions and regional recovery intentionally

Need	Pattern	Design question
one database is too large/hot	partition/shard by tenant or order ID	can one order ever require a cross-shard transaction?
read traffic dominates	replicas or CQRS projection	how stale may a read be?
single-region outage tolerance	active-passive disaster recovery	what are acceptable RPO and RTO?
global low-latency writes	multi-region ownership/partitioning	which region owns a given order to avoid conflicting writes?

Start with a tested backup and restore, then regional failover drills. Multi-region active-active writes are a product and data-consistency decision, not a switch on a load balancer. Use them only when the RPO/RTO and latency requirements justify the complexity.

Failure clinic

Symptom	Cause	Fix
database CPU spikes after popular cache key expires	every replica misses at once	jitter TTLs, stale-while-revalidate, single-flight/lease, capacity test hot keys
stale catalog price used for payment	cache used for a correctness-critical decision	revalidate authoritative price during order command
services cannot deploy independently	shared tables and cross-service joins	establish service-owned data and event/API boundaries
shard migration becomes an emergency	shard key chosen without growth/rebalancing plan	record routing metadata, design tenant move procedure, test it before scale requires it
disaster recovery plan exists only in a document	backup/restore never exercised	run restore and regional failover game days; measure actual RPO/RTO

Advanced capstone — Operate the platform through a release and traffic

incident

Run this scenario in teams:

1. A new shipping consumer expects `delivery_window`, but old `OrderCreated` events do not have it.
2. A promotion creates 20x export traffic from one tenant.
3. Payment latency rises and the canary version has a higher timeout rate.
4. During rollback, an order-service Pod is terminated with work in flight.

The team must:

- Use traces, metrics, queue age, and DLQ dashboards to diagnose the impact.
- Shed/defer low-priority exports while preserving checkout capacity.
- Route poison/old events through the compatibility path or DLQ, then replay safely.
- Halt or roll back the canary based on an explicit promotion threshold.
- Confirm no duplicate charge, duplicate shipment, dropped order event, or cross-tenant access occurred.

Extended completion rubric

- Traffic is admitted according to tenant quota, operation cost, and system capacity.
- Asynchronous failures have retry, DLQ, repair ownership, and replay semantics.
- Event and API contracts survive independent producer/consumer deployments.
- One trace connects ingress, API, database/outbox, messaging, saga, and downstream calls.
- Alerts are tied to SLO/error-budget impact and asynchronous workflow health.
- Identity, authorization, data ownership, and tenant isolation are enforced at more than one layer.
- Every release is compatible with a mixed fleet and can be halted or rolled back safely.
- Cache behavior, partitioning strategy, backup/restore, and regional recovery have explicit correctness and recovery assumptions.

Interactive incident drills

Use these after the labs. Read only the scenario first, decide what you would do, then expand the answer. A strong answer names the **failure boundary**, the **pattern**, the **evidence**, and the **safe user-visible result**.

Drill 1 — “The user says they were charged twice”

Scenario: The gateway retried a `POST /orders` after a network timeout. The order service returned no response to the client. Payment shows two authorization attempts.

▶ Reveal the investigation and design answer

Drill 2 — “Kafka lag rises but API success is 99.99%”

Scenario: `POST /orders` is fast and successful, but confirmation emails and shipping updates are delayed by 45 minutes.

▶ Reveal the investigation and design answer

Drill 3 — “A canary looks healthy, but customers cannot complete checkout”

Scenario: The canary returns HTTP 200 for checkout requests. Twenty minutes later, `PAYMENT_AUTHORIZED` orders remain stuck and shipping has not started.

▶ Reveal the investigation and design answer

Drill 4 — “A support token accesses another tenant’s order”

Scenario: The caller has `orders:read`, but the request URL contains an order from a different tenant.

▶ Reveal the investigation and design answer

Drill 5 — Choose the next pattern

Complete the blanks before opening the answer:

```
1. Database commit succeeds, event publish is lost      -> _____________
2. Slow payment dependency consumes every worker        -> _____________
3. Consumer fails forever on malformed event            -> _____________
4. Dashboard query slows order creation                 -> _____________
5. Two services must reverse business steps on failure  -> _____________
6. Cache expiry creates thousands of database reads     -> _____________
```

▶ Reveal answers

Self-learning runbook and review checklist

Use this section as your navigation when you return to the workshop after a break. It states what must be running, the proof of completion, and the most likely first diagnostic step.

Start and stop safely

Core local environment: Labs 0-7

```
# Start only infrastructure. FastAPI and mocks run in separate
        terminals.
docker compose -f infra/compose.yaml up -d postgres redpanda

# Start the FastAPI service using the host environment file.
uv run uvicorn services.order_service.app.main:app --env-file .env --
        reload --port 8000

# When finished with core labs, preserve volumes or remove them
        intentionally.
docker compose -f infra/compose.yaml down
# To erase local database/event state as well:
# docker compose -f infra/compose.yaml down --volumes
```

Compose gateway environment: Labs 4-7 and 9-11

```
docker compose -f infra/compose.yaml up --build -d
docker compose -f infra/compose.yaml logs -f kong order-service

# The external boundary is Kong. Use /api, never a direct application
        port.
curl -i http://localhost:8000/api/livez
```

Kubernetes platform environment: Lab 8 and platform parts of Labs 12-13

```
kubectl config current-context
kubectl get namespace orders
kubectl -n orders get pods,svc,hpa
kubectl -n orders logs deployment/order-service -c app --tail=50
kubectl -n orders logs deployment/order-service -c istio-proxy --
        tail=50
```

Caution

Never run **docker compose down --volumes** casually. It deliberately deletes the learning database and message state. Use it only when the lab tells you to reset state or when you want to repeat from a clean slate.

Completion evidence by lab

Lab	Minimum evidence you should save	If it fails, inspect first
0	GET /livez returns 200; missing DATABASE_URL causes startup failure	terminal environment and .env path
1	invalid UUID returns 422; blocking endpoint visibly delays concurrent requests	route registration and request body/header
2	same idempotency key returns one order ID; database has one row	orders/idempotency_keys rows and transaction logs
3	injected delay yields bounded timeout; later requests fail fast while breaker is open	mock dependency port, client deadline, breaker state
4	/api/v1/orders returns 202 through Kong; direct application address is absent	Kong config mount, strip_path, Compose DNS
5	crash-after-write scenario leaves unpublished outbox row; publisher later marks it published	outbox table, producer logs, topic key
6	shipping failure results in void/release or COMPENSATION_PENDING	durable order status and operation IDs
7	query model can lag; aggregate version conflict is rejected/retried	projection offset and event version
8	Pod contains istio-proxy; ingress /api/livez returns 200	namespace injection label, image loading, gateway/VirtualService
9	overload returns 429/503 before worker exhaustion; queue age stays measurable	rate-limit key, semaphore limit, consumer lag
10	malformed message ends in DLQ after bounded attempts; replay is idempotent	retry headers, DLQ owner, consumer dedupe table
11	one trace connects ingress to downstream event/saga work	trace propagation headers and metric label cardinality
12	wrong scope or wrong tenant returns 403/404 without leaking data	token validation, tenant predicate, mesh policy
13	canary sees business metrics; migration stays compatible with old code	rollout status, feature-flag default, schema phase

Lab	Minimum evidence you should save	If it fails, inspect first
14	cache miss does not stampede database; restore/failover target is documented	TTL policy, key ownership, RPO/RTO exercise

Common ambiguity breakers

Question	Course answer
“Should I call a Pod IP?”	No. Compose service name locally; Kubernetes Service name in cluster.
“Should every request go through Kafka?”	No. Keep immediate user commands synchronous when they need an immediate decision; use events for durable cross-service propagation and long-running work.
“Does a circuit breaker guarantee no duplicate payment?”	No. Idempotency at your payment operation boundary does that.
“Does exactly-once Kafka delivery solve business duplicates?”	No. Consumers still require dedupe/idempotent effects.
“Can a mesh replace saga logic?”	No. Mesh controls transport behavior; a saga owns business progress and compensation.
“Is Kubernetes required to learn FastAPI production patterns?”	No. Compose teaches application behavior first; Kubernetes makes platform responsibilities explicit later.
“Should cache be the source of truth?”	Normally no. Use authoritative storage for correctness-critical writes and decisions.

Deliberately simplified versus production-required

Learning simplification	Production requirement before launch
local Postgres password and environment file	managed secret store, rotation, least-privilege database account
mock payment/inventory services	contract tests, sandbox accounts, provider-specific idempotency and reconciliation
local Kong policy	distributed tenant quota, WAF, auth plugin, gateway SLOs
short in-process publisher example	supervised worker/CDC, deployment lifecycle, topic ACLs, schema registry
placeholder Kubernetes dependency URLs	managed dependencies, real readiness policy, backup and restore validation
illustrative authorization principal	OIDC issuer/audience/JWKS validation, workload identity, resource/tenant authorization

If a step uses a simplification, the table tells you the next production question to ask. This prevents the common mistake of treating a workshop shortcut as an enterprise architecture recommendation.